

Axiom AI Technologies

Security Remediation Plan

Document ID: AAI-SRP-2026-001

Version: 1.0

Classification: Internal Use

Document Status: Approved for Portfolio Use

Document Owner: Information Security / GRC

Review Frequency: At least annually and following significant security or organizational changes

1. Executive Summary

This Security Remediation Plan defines the corrective actions required to address vulnerabilities identified during the Axiom AI Vulnerability Management Assessment.

The plan demonstrates a structured, risk-based approach to reducing security risk through defined remediation activities, ownership, target dates, compensating controls, validation requirements, and residual-risk decisions.

The assessment identified 12 simulated security findings across application, cloud, identity, network, database, endpoint, and resilience environments.

- 1 Critical finding
- 5 High findings
- 6 Moderate findings
- 0 Low findings

Portfolio Disclaimer: This case study is inspired by and based on real professional cybersecurity and GRC practices. Axiom AI Technologies is a fictional organization. All systems, vulnerabilities, remediation activities, dates, evidence, and findings are simulated for portfolio and educational purposes.

2. Purpose

- Translate identified vulnerabilities into actionable corrective measures.
- Establish remediation priorities.
- Assign risk and remediation ownership.
- Define target remediation timelines.
- Identify compensating controls.
- Establish validation requirements.
- Track remediation status.
- Define escalation requirements.
- Manage residual risk.
- Support formal risk acceptance where required.
- Provide evidence of continual security improvement.

3. Scope

This remediation plan covers the simulated findings identified within the Axiom AI Vulnerability Management Assessment.

In Scope

- Cloud infrastructure
- Web applications
- APIs
- Identity and access management
- Virtual machines
- Network services
- Databases
- Application dependencies
- Secrets management
- Logging and monitoring
- Backup and recovery configurations

Out of Scope

- Live vulnerability remediation
- Real production systems
- Real customer data
- Real credentials
- Live exploitation
- Penetration testing
- Unauthorized access
- Real malware
- Production infrastructure changes

4. Remediation Methodology

The remediation process follows a continuous lifecycle:

Identify → Assess → Prioritize → Assign → Plan → Remediate → Validate → Close / Accept Risk → Monitor → Improve

5. Remediation Prioritization

Remediation priority considers technical severity, exploitability, asset criticality, business impact, exposure, existing security controls, threat context, availability of remediation, compensating controls, and residual risk.

Severity	Target
Critical	Immediate / accelerated remediation
High	Within 30 days
Moderate	Within 60 days
Low	Within 90 days

6. Remediation Summary

Finding	Severity	Primary Remediation	Owner	Target	Status
VULN-001	High	Upgrade vulnerable application dependency	Application Security Lead	2026-10-30	Open
VULN-002	High	Restrict cloud storage permissions	Cloud Platform Engineer	2026-10-23	In Progress
VULN-003	Moderate	Implement security headers	Web Platform Engineer	2026-11-15	Open
VULN-004	High	Reduce service-account privileges	IAM Administrator	2026-10-23	Open
VULN-005	Moderate	Apply operating-system security updates	Systems Administrator	2026-11-15	In Progress
VULN-006	Moderate	Enable required database audit logging	Database Administrator	2026-11-30	Open
VULN-007	Critical	Remove public administrative exposure	Cloud Platform Engineer	2026-10-10	In Progress
VULN-008	High	Rotate application credential	DevOps Engineer	2026-10-30	Open
VULN-009	Moderate	Disable legacy TLS configuration	Network Engineer	2026-11-30	Open
VULN-010	Moderate	Implement authentication-failure alerting	SOC / Detection Engineer	2026-11-15	Open
VULN-011	High	Remove unnecessary exposed network port	Systems Administrator	2026-10-30	Open
VULN-012	High	Correct backup configuration	Database Administrator	2026-10-30	Open

7.1 VULN-001 — Unsupported Third-Party Library

Severity	High
CVSS-Style Score	8.1
Affected Asset	Customer API Service
Owner	Application Security Lead
Target Date	2026-10-30
Status	Open
Residual Risk	High

Finding / Remediation

Upgrade to a supported library version and validate application compatibility.

Implementation Steps

- Identify dependency and version
- confirm supported version
- upgrade
- test compatibility
- deploy through change management
- validate vulnerable version is no longer present.

Compensating Control

Monitor application activity; restrict unnecessary functionality where practical; increase security-event review.

Validation Evidence

- Dependency inventory
- updated manifest
- change record
- application test results
- security validation.

7.2 VULN-002 — Overly Permissive Cloud Storage Access

Severity	High
CVSS-Style Score	8.8
Affected Asset	Object Storage Bucket
Owner	Cloud Platform Engineer
Target Date	2026-10-23
Status	Remediation In Progress
Residual Risk	High

Finding / Remediation

Restrict permissions to approved identities and required actions.

Implementation Steps

- Review current permissions
- identify legitimate users/services
- remove unnecessary permissions
- restrict actions
- review IAM policies
- validate access.

Compensating Control

Temporary deny policies where appropriate; enhanced access monitoring; periodic storage-log review.

Validation Evidence

- IAM policy
- access review

- change record
- access validation.

7.3 VULN-003 — Missing Security Headers

Severity	Moderate
CVSS-Style Score	6.5
Affected Asset	Customer Web Portal
Owner	Web Platform Engineer
Target Date	2026-11-15
Status	Open
Residual Risk	Moderate

Finding / Remediation

Implement and validate the approved security-header baseline.

Implementation Steps

- Implement headers through application or reverse proxy
- test consistency across the customer-facing application.

Compensating Control

Maintain WAF protections; monitor unusual application traffic; review security configuration during releases.

Validation Evidence

- Configuration record
- application tests
- header validation
- change record.

7.4 VULN-004 — Excessive Service-Account Privileges

Severity	High
CVSS-Style Score	8.0
Affected Asset	AI Processing Service Account
Owner	IAM Administrator
Target Date	2026-10-23
Status	Open
Residual Risk	High

Finding / Remediation

Reduce permissions to the minimum required for normal operations.

Implementation Steps

- Review permissions
- identify required access
- remove unnecessary privileges
- test functionality

- monitor after change.

Compensating Control

Enhanced service-account logging; periodic activity review; restrict unnecessary access.

Validation Evidence

- IAM policy
- access review
- activity logs
- functional validation.

7.5 VULN-005 — Operating System Patch Baseline

Severity	Moderate
CVSS-Style Score	7.1
Affected Asset	Development Virtual Machine
Owner	Systems Administrator
Target Date	2026-11-15
Status	Remediation In Progress
Residual Risk	Moderate

Finding / Remediation

Apply approved security updates and verify patch-baseline compliance.

Implementation Steps

- Identify missing updates
- confirm compatibility
- apply updates
- restart if required
- confirm operation
- verify baseline.

Compensating Control

Restrict unnecessary network access; maintain endpoint protection; increase monitoring.

Validation Evidence

- Patch report
- system configuration
- endpoint status
- validation record.

7.6 VULN-006 — Database Logging Gap

Severity	Moderate
CVSS-Style Score	5.9
Affected Asset	Analytics Database
Owner	Database Administrator
Target Date	2026-11-30

Status	Open
Residual Risk	Moderate

Finding / Remediation

Enable required database audit events and forward them to centralized monitoring.

Implementation Steps

- Identify required audit events
- enable configuration
- forward events
- confirm receipt
- validate monitoring coverage.

Compensating Control

Increase manual review of available database and cloud logs.

Validation Evidence

- Audit configuration
- central logging evidence
- sample events
- monitoring validation.

7.7 VULN-007 — Public Administrative Endpoint

Severity	Critical
CVSS-Style Score	9.1
Affected Asset	Management Interface
Owner	Cloud Platform Engineer
Target Date	2026-10-10
Status	Remediation In Progress
Residual Risk	Critical

Finding / Remediation

Remove public exposure and restrict administrative access through approved secure access paths.

Implementation Steps

- Confirm interface
- restrict exposure
- remove public accessibility
- limit administrative access
- review authentication and access logs
- validate final network configuration.

Compensating Control

Emergency network restrictions; increased monitoring; access-event review; management escalation.

Validation Evidence

- Network configuration
- access controls
- firewall/security-group rules
- access-log review
- validation test.

7.8 VULN-008 — Inadequate Secrets Rotation

Severity	High
CVSS-Style Score	7.5
Affected Asset	Application Integration Service
Owner	DevOps Engineer
Target Date	2026-10-30
Status	Open
Residual Risk	High

Finding / Remediation

Rotate the credential and establish an appropriate rotation mechanism.

Implementation Steps

- Identify credential
- confirm dependencies
- generate replacement
- update secret storage and services
- revoke old credential
- validate
- establish rotation.

Compensating Control

Restrict credential permissions; monitor usage; review access logs.

Validation Evidence

- Secrets-management record
- rotation record
- application validation
- revocation evidence.

7.9 VULN-009 — Weak TLS Configuration

Severity	Moderate
CVSS-Style Score	6.4
Affected Asset	Internal Integration Service
Owner	Network Engineer
Target Date	2026-11-30
Status	Open
Residual Risk	Moderate

Finding / Remediation

Disable legacy cryptographic configurations and enforce approved TLS standards.

Implementation Steps

- Identify legacy configuration
- confirm standard
- disable unsupported protocols
- validate compatibility
- confirm approved encryption.

Compensating Control

Restrict access to trusted internal segments until corrected.

Validation Evidence

- TLS configuration
- baseline
- validation results
- change record.

7.10 VULN-010 — Authentication-Failure Alerting Gap

Severity	Moderate
CVSS-Style Score	6.8
Affected Asset	Identity Platform
Owner	SOC / Detection Engineer
Target Date	2026-11-15
Status	Open
Residual Risk	Moderate

Finding / Remediation

Create and validate detection logic for abnormal authentication failures.

Implementation Steps

- Define patterns
- develop detection
- configure thresholds
- test alerts
- tune false positives
- document rule.

Compensating Control

Periodic manual review of authentication logs until automated detection is validated.

Validation Evidence

- Detection rule
- test event
- alert record
- monitoring documentation.

7.11 VULN-011 — Unnecessary Network Port Exposure

Severity	High
CVSS-Style Score	7.2
Affected Asset	Application Host
Owner	Systems Administrator
Target Date	2026-10-30
Status	Open
Residual Risk	High

Finding / Remediation

Disable unnecessary service and remove corresponding network exposure.

Implementation Steps

- Identify service
- confirm it is not required
- disable it
- remove exposure
- review firewall/security-group rules
- confirm operation
- monitor connections.

Compensating Control

Restrict source networks and increase monitoring until exposure is removed.

Validation Evidence

- Host configuration
- firewall/security-group configuration
- service status
- connection validation.

7.12 VULN-012 — Backup Configuration Gap

Severity	High
CVSS-Style Score	7.6
Affected Asset	Application Database Backup
Owner	Database Administrator
Target Date	2026-10-30
Status	Open
Residual Risk	High

Finding / Remediation

Correct backup configuration and conduct a controlled recovery validation.

Implementation Steps

- Review recovery objectives
- compare configuration
- correct frequency/retention

- verify backup completion
- conduct recovery validation
- document results.

Compensating Control

Increase backup verification and integrity checks; document temporary recovery procedures.

Validation Evidence

- Backup configuration
- successful backup record
- recovery test
- recovery documentation
- updated BCP/DR evidence.

8. Remediation Validation Framework

Each completed remediation should undergo validation.

Step 1 — Confirm Implementation

Verify that the corrective action was implemented.

Step 2 — Confirm Security Effectiveness

Determine whether the original vulnerability or control weakness has been addressed.

Step 3 — Review Evidence

Collect appropriate technical and governance evidence.

Step 4 — Assess Residual Risk

Determine whether remaining risk is acceptable.

Step 5 — Close or Escalate

Close the finding if successful; otherwise return it to remediation.

9. Validation Status

Status	Definition
Not Yet Validated	Remediation has not yet been validated.
Validation In Progress	Validation activities are underway.
Validated	Remediation has been successfully verified.
Failed Validation	Remediation did not adequately address the finding.

A finding should not be marked Closed unless remediation has been successfully validated or an approved risk-acceptance decision has been documented.

10. Risk Exception Process

Where a finding cannot be remediated within the target timeframe, a formal exception may be requested.

- Finding ID
- Vulnerability
- Business justification
- Current risk
- Proposed compensating controls
- Residual risk
- Risk owner
- Approval authority
- Expiration/review date
- Planned remediation date

Risk exceptions should be reviewed periodically and should not be treated as permanent authorization for unresolved vulnerabilities.

11. Escalation Criteria

- A Critical finding remains unresolved.
- A High finding exceeds its remediation target.
- The remediation owner identifies a significant blocker.
- The vulnerability becomes materially more dangerous.
- A compensating control fails.
- Residual risk exceeds organizational tolerance.
- Management approval is required for risk acceptance.

12. Management Reporting

Metric	Purpose
Open Findings	Measures outstanding security weaknesses.
Critical Findings	Identifies highest-priority unresolved risk.
High Findings	Tracks significant security exposure.
Average Time to Remediation	Measures remediation efficiency.
SLA Compliance	Measures findings remediated within target.
Overdue Findings	Identifies remediation delays.
Failed Validations	Identifies ineffective corrective actions.
Risk Exceptions	Tracks vulnerabilities requiring formal acceptance.
Residual Risk	Measures remaining exposure after remediation.

13. Remediation Governance

- Risk management
- Change management
- Vulnerability management
- Security operations
- Access management
- Configuration management
- Incident response
- Business continuity

- Internal audit
- Management review
- Continual improvement

Remediation evidence should be retained according to the organization's evidence-management requirements.

14. Framework Alignment

This remediation plan supports alignment with ISO/IEC 27001:2022, NIST Cybersecurity Framework (CSF) 2.0, NIST SP 800-30, NIST SP 800-53, and CIS Controls.

15. Relationship to Project 4 — Business Continuity

VULN-012 demonstrates the relationship between vulnerability management and business continuity. Security weaknesses affecting backup and recovery capabilities can directly affect recovery objectives, availability, operational resilience, disaster recovery, and business continuity.

The remediation process therefore incorporates recovery validation rather than treating backup configuration as solely a technical infrastructure concern.

16. Closure Criteria

- Corrective action has been implemented.
- Appropriate evidence has been collected.
- Validation confirms the vulnerability has been addressed.
- Residual risk is acceptable.
- Required stakeholders have approved closure.

Alternatively, a finding may be moved to an approved risk-acceptance state when the remaining risk is understood, authorization is obtained, compensating controls are documented, and a review or expiration date is established.

17. Document Ownership and Review

Document Owner: Information Security / GRC

The document owner is responsible for maintaining this remediation plan and ensuring that significant changes to the methodology are appropriately reviewed.

- At least annually.
- Following significant changes to the vulnerability-management process.
- Following major security incidents.
- Following significant organizational or technology changes.
- When material changes are made to the underlying risk-management framework.

The underlying remediation register should be updated as findings change status, new findings are identified, or remediation activities are completed.

18. Portfolio Limitations

This document represents a simulated professional cybersecurity case study. It does not represent a real production remediation program, access to Axiom AI infrastructure, real vulnerability findings, real customer information, real credentials, live exploitation, unauthorized testing, or actual security incidents. All remediation activities, systems, findings, owners, dates, and evidence are simulated.

19. Conclusion

The Axiom AI Security Remediation Plan demonstrates a structured approach to converting vulnerability findings into measurable security improvements.

Vulnerability → Risk → Priority → Ownership → Corrective Action → Remediation → Validation → Residual Risk → Closure / Acceptance

This approach supports the broader Axiom AI ISMS by ensuring that identified security weaknesses are actively managed rather than simply documented. The remediation process also provides a foundation for continual improvement and feeds security findings back into risk management, controls assessment, incident response, business continuity, and security governance.

Next Stage: 03-malware-analysis